

COMP6441 Week 2 Portfolio

Name: chuanze

zID:5659271

Date Submitted:

1. Setup

Security Everywhere

This week's Security Everywhere theme is that I have been receiving text messages from Anytime Fitness and even received calls from Anytime Fitness around noon on Tuesday.

The cause of the matter is very simple. I saw a new activity launched by Anytime Fitness on the Internet, which advertises that you only need 1 yuan a week to become a member for the first 6 weeks. Because I want to confirm whether this activity is real, I clicked on their website. However, the problem with this website is that it does not directly display the specific package price but requires users to fill in personal information before they can enter the next step to check the price.

So I entered my personal information in the form and then clicked on the next step. As a result, I found that the price in the back was not what I understood at the beginning, "1 yuan per week for the first 6 weeks", so I did not continue to register and closed the web page directly. But even if I don't complete the whole registration process, the website still saves the personal information I have entered. This also explains why I have been receiving text messages and calls from Anytime Fitness since then.

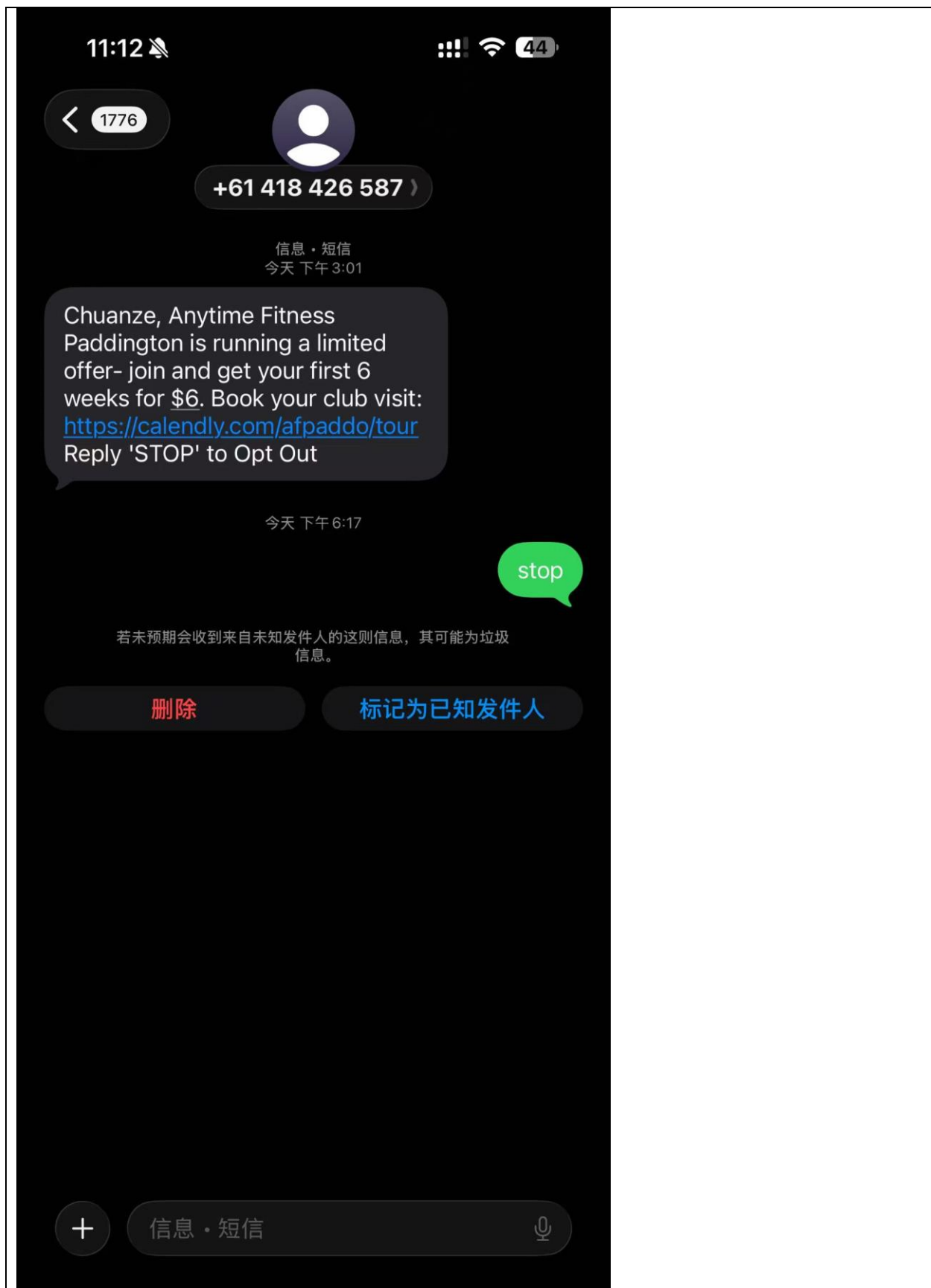
This incident made me realize that once the user enters personal information into the website, how the information is used later is not completely controlled by the user. The website system may directly judge me as a potential customer and then add my mobile phone number to the marketing list and continue to send me advertising information.

The problem here is not just as simple as "receiving harassing text messages", it will also bring deeper security risks. Because I'm used to Anytime Fitness texting me, so if I really want to join the gym in the future, it may be easier to believe these text messages and click the link in the text message directly. If the attacker imitates the text message style of Anytime Fitness and sends similar advertising messages or registration links, it may be difficult for me to distinguish the truth first. Anytime Fitness's text messages and calls may come from different numbers, which makes it more difficult for users to judge whether the information is credible by the number. Attackers can use this habit of trust to guide users to fake web pages and let them continue to fill in bank cards, addresses, birthdays or other personal information.

Therefore, I think the best way to do this kind of situation is prevention, not to wait for detection after receiving the text message. The prevention method can be when just checking the price or activity details, don't fill in your main mobile phone number too early. You can use the backup contact information first or fill in the real personal information after you really decide to register as a member. This can reduce the risk of personal information being saved and used for marketing by the website in advance and can also reduce subsequent harassment of text messages.

Of course, if you have received this kind of text message, you can also try to detect it. For example, check whether the link domain name in the text message is consistent with the official website, observe whether the link in different text messages use the same domain name, and pay attention to whether there are strange spellings, extra characters or content unrelated to the gym in the link. However, detection itself is relatively difficult, because ordinary users cannot carefully check the domain name every time they receive a marketing text message. And if the text message format looks normal, it is easy for users to believe it directly.

From the perspective of the gym, this practice does improve marketing efficiency. As long as users have filled in their personal information on the website, even if the registration has not been completed, the gym can continue to contact them by text message and phone. For some users who are really interested, this may increase the conversion rate. But from the user's point of view, this is a trade-off between efficiency and privacy. The gym has gained more marketing opportunities, but users have lost control over the use of personal information, which also increases the risk of being deceived by phishing text messages in the future.



2.Security Engineering

Decryption Game

Welcome to the UNSW SECedu Cyber Foundations NSA Game Challenge Bot

THE DANGER IN BEING KING IS THAT AFTER
TWI MXFPIZ QF BIQFP YQFP QA TWXT XJTIZ
A WHILE YOU BEGIN TO BELIEVE YOU REALLY
X HWQEI VUS BIPQF TU BIEQIOI VUS ZIXEEV
ARE ONE.
XZI UFI.

Cipher solved! You are awesome! You solved the cipher:
THE DANGER IN BEING KING IS THAT AFTER A WHILE YOU BEGIN TO BELIEVE YOU REALLY ARE ONE.

ClearEnable JumpChange Cipher

A	S	B	B	C		D		E	L	F	N	G		H	W	I	E	J	F
K		L		M	D														
N		O	V	P	G	Q	I	R		S	U	T	T	U	O	V	Y	W	H
X	A	Y	K	Z	R														

I mainly start with short words, common words and sentence structures, instead of randomly guessing letters.

First, I see that X is a separate letter, and the word with a single letter in English is usually a or I. Combined with the following structure, I first guess X = a.

Then I saw TWXT, because I already knew X = a, so the word became __ a __, and the first and last letters were the same, so I guess it was that, from which T = t, W = h. Then TWI became th_, so it was obviously the, so it was determined that I = e.

After that, I saw TU, because T = t, so it is t_. I guess it is a common two-letter word to, so U = o.

After having U = o, VUS becomes _ o __, and the word appears twice in the sentence, and the position is very similar to the subject or object, so I guess it is you, get V = y and S = u.

Next, I look at HWQEI, and it is displayed as _ h __ e. At first, you may think of where, but the third and fifth letters of where are both e, and in substitution cipher, different cipher letters generally cannot represent the same plaintext letters, so it is unlikely to be where. Combined with the previous X HWQEI VUS, that is, a _ h __ e you, I think it is more like a while you, so make sure HWQEI = while and launch H = w, Q = i, E = l.

Then I look at QF, because Q = i, so it is i_, which may be in / is / it / if, but T is already t, so F should no longer be t. Combined with the sentence structure, I judge QF = in, so F = n. This step was verified by the following BIQFP, because after substitution, it becomes _ e i n __, which is obviously being, so B = b, P = g can be introduced.

Then YQFP becomes _ing, and it is preceded by being, so an identity or noun should be followed here, not an ordinary verb, so I judge that it is king and put forward Y = k. By this time, the sentences can basically be read, and the remaining -ANGE-, A-TE-, BELIE-E, -EALLY and A-E can be directly supplemented into danger, after, believe, really and are according to the context. The last whole sentence is: *The danger in being king is that after a while you begin to believe you really are one.*

This process shows that the weakness of substitution cipher is that although it replaces letters, it still retains word length, repeated letter patterns and sentence structure. Because English itself has many fixed language habits, such as common articles, prepositions, pronouns and phrases, as long as you start with the simplest and most common words, you can deduce more letters step by step. After the key words are cracked, the context will become clearer and clearer, and finally the whole sentence can be introduced. This also shows that simple replacement passwords are not safe, because it hides the letters themselves, but does not really hide the structure and laws of the language.

Classical Ciphers

Janice Janice Joju

Cipher: Caesar Cipher

Shift: -14

Encrypted Message: RURMIADXPOGB

https://en.wikipedia.org/wiki/Caesar_cipher

Shift -14

R → F

U → I

R → F

M → A

I → W

A → O

D → R

X → L

P → D

O → C

G → U

B → P

Solution: FIFAWORLDCUP

I also used Caesar cypher for encryption. Simply put, Caesar cypher is a very basic substitution cypher, that is, replacing each letter in the plaintext with a letter in another position in the alphabet according to a fixed number of shifts.

For example, the word I want to encrypt is GOODLUCK, and the key I use is shift +5, that is, each letter moves back 5 digits. So G will become L, O will become T, D will become I, and so on. The final text obtained is LTTIQZHP.

This encryption method is very simple and easy to complete manually, but its security is not high. The biggest limitation is that there are only 26 letters in the English alphabet, so there are only 1 to 25 valid shifts. That is to say, even if the attacker

doesn't want to guess according to the language law at all, he can directly try all possible shifts. For modern computers, this kind of brute force cracking has almost no pressure.

Its complexity does not increase exponentially, but tries up to 25 times, and only needs to move the whole text once each time, so the actual cracking cost is very low. Therefore, Caesar cypher is more like an example of helping to understand classical encryption ideas than a truly reliable encryption method.

Project Proposal

Project Proposal Template

The project proposal is how the course will judge the progress of your own project. Illustrated below is a template that you should use in your Week 2 project update blog.

Project Goal:	my goal is to investigate how client-side game data modification works in a controlled and ethical environment, and to explain why online games should not trust the client. I will compare a simple offline single-player example with a minimal local client-server demo to show the difference between client-side trust and server-side validation.
Project Description (more depth):	This project mainly focusses on the security issues caused by excessive trust in the game client. In many offline single-player games, life value, gold coins, scores or archive data may be stored on the player's own computer. Because these data are local, players can sometimes change the game status by modifying the local data, and this modification usually only affects their own game experience. But the situation of online games is different. In online RPG or multiplayer online games, important data such as gold coins, items, experience points, damage, transaction records, achievements and ranking scores should not be fully trusted by the client. If the server directly accepts the value sent by the client, the player may gain an unfair advantage by modifying the client data. Therefore,

		the server should maintain the real game status and check whether the operation sent by the player is reasonable. In the practical part, I will not make a complete game, but a very small demonstration program. This demonstration will include two stages and use the same set of simple game data. In the first stage, there is only the client, which saves data such as gold coins or life value locally. Users can directly modify these data files to change the game value and show the problem of client data tampering. In the second stage, the server verification mechanism is added in the same scenario. The client no longer directly decides the final value, but sends an operation request to the server, and the server checks whether the request is legal and updates the game status. By comparing these two stages, it is more intuitive to show how server-side verification can reduce the risk of client data tampering. This project will abide by the moral boundaries. I will not test cheating methods in real online games, nor will I try to bypass the anti-cheating system, let alone modify any real online game data. All practical tests will be completed in a local, offline and controlled environment. The focus of this project is not to make cheating tools, but to understand why online games cannot fully trust the client and the role of server-side verification in security design.	
Project Schedule:	Week 2	narrowed scope and asked for tutor's approval. Build initial proposal	
	Week 3	Build a local demo without client validation	<i>Note: Project Proposal Due Monday 4PM with Week 2 Portfolio</i>
	Week 4	Add a basic client-server structure	
	Week 5	Finalize the demo by adding server-side validation	

	Week 6	-- Flexibility Week --	
	Week 7	Research more case studies	
	Week 8	Finalizes the report	<i>Note: Final Report Deliverable Due Friday 4PM 24th July</i>
Project Deliverables/Outcomes:		<i>[What will the outcome and deliverables from your project?]</i> The outcome of this project will be a small local demo and a written analysis. The demo will use a simple game-like scenario with values such as coins or health. It will first show what can happen when game data is stored or controlled locally without validation and then show how the same situation changes when a server is added to validate client requests. The main deliverables will include the local demo code, screenshots or output logs showing the results, and a final report explaining the security concept. The report will compare client-side trust with server-side validation, discuss why online games should not fully trust client-side data, and analyze where these defenses can still fall short. The project will also include a small number of public case studies related to online game exploits, such as item duplication, currency manipulation, or weak reward validation. These case studies will be used to connect the demo to real-world security problems.	

3. Analysis and Reflection

Tutorial 2: Doors

The topic of this week's tutorial discussion is aircraft safety issues, and what suggestions we can give if we want to prevent plane accidents, and sort these suggestions according to their importance. The interesting point of this week's topic is that the problem does not necessarily come only from the outside. For example, if the attacker attacks from the outside, it is also necessary to consider whether the person who is already in the cockpit will become a risk.

First of all, we think the most important thing is to add a mechanism similar to two-person rule, that is, a pilot cannot have full control alone during the flight. According to these rules, it reminds me of the separation of duties in network security. It is a risk for a person's authority to be infinitely amplified, because the direction of things will be completely dominated by this person.

The second point is to conduct regular mental health assessments for pilots, just like what I mentioned above. The possible problem is not external attacks, but internal problems. This is very similar to the insider threat in network security. Even if a person has legal authorization, it does not mean that he will always be safe.

The third suggestion is to add additional verification methods to the cockpit door, such as fingerprint or facial recognition. He can confirm whether the person entering the cockpit is an authorized person to avoid many external risks. But when we discussed it, we also found that this method was not perfect. For example, if the equipment is broken, or if the pilot is injured in an emergency and facial recognition fails, the legal person may not be able to enter. So, this is also a trade-off between security and useability. The system can not only pursue "absolute safety closure" but also ensure that legal personnel can still enter in case of emergency.

The fourth suggestion is to allow the ground tower to remotely take over the aircraft when the aircraft is abnormal. This idea is put in the fourth point because it is difficult to realize, and after careful discussion, some loopholes were found, that is, the attacker can directly attack the tower to obtain control of the aircraft.

Two-person rule and regular mental health assessment are more inclined to prevention, which is to reduce the possibility of a single person abusing authority before the problem occurs; while tower monitoring aircraft abnormalities are more like detection, which is to return as soon as possible after abnormal behavior is found. Response; Remote takeover or emergency entry into the cockpit is more like recovery, but these methods themselves may cause some other unexpected chain reactions, so there is no absolutely safe option.

Through discussion, I found that the real difficulty is that adding new security measures is not necessarily positive feedback. Every new feature may bring new

risks at the same time. The real difficulty is to find a balance between preventing external attacks, restricting excessive authority of internal personnel, discovering abnormal behavior, and restoring control in emergency situations.

4.Wrap up

Submission Instructions

To submit a valid portfolio entry, complete the activities, save your work as a PDF, and upload it to the relevant week's submission page on Moodle.